TLP:CLEAR

ОТЧЁТ ОБ ИНЦИДЕНТЕ

Поддельное уведомление YouTube DMCA через группу Google: кит «Copyright Library»

Phishing • Google Groups • share.google • Fake DMCA Notice • Credential Theft • Cybercrime

Параметр	Значение
Дата анализа	**21 октября 2026**
Классификация	**Credential-фишинг: поддельное уведомление YouTube об авторских правах**
Актор	**Не установлен; русскоязычный разработчик (строки интерфейса), движок «collabix»; родство с PhaaS-семейством апреля 2026 по коду не подтверждено; не связан с параллельным случаем под Hetzner (High)**
Цели	**Владельцы каналов YouTube и участники использованной группы**
Затронутые системы	**Google-аккаунты получателей**
Ключевые техники	**Доставка через Google Groups, короткая ссылка share.google, окно Browser-in-the-Browser с живым оператором, перехват вторых факторов, obfuscator.io, domain-lock и DOM-шум**
Уровень угрозы (оценка риска кампании)	**HIGH**
Источники	**Заголовки и тело письма; пассивный DNS, прозрачность сертификатов, RDAP, публичные архивы сканов**

1. Краткое резюме

13 октября 2026 года поддельное уведомление YouTube об авторских правах было разослано через группу Google её участникам; нам о нём сообщили 21 октября. Ссылка ведёт на действующий credential-фишинговый кит, имитирующий DMCA-страйк и оверлей входа Google. Отдельное письмо, исследованное параллельно, с этой кампанией не связано (уверенность High).

Сообщение опубликовано в группе Google и разослано участникам с собственной DKIM-подписью Google. Ссылка — короткая share.google, ведущая на copyright-library[.]com: действующий кит «Copyright Library». Посетитель вводит ссылку на канал, видит фальшивый «DMCA strike 1/3» и попадает в поддельное окно браузера (Browser-in-the-Browser), имитирующее вход в Google. Окном в реальном времени управляет оператор; кит поддерживает перехват пароля и всех распространённых вторых факторов. Кит прячется за obfuscator.io, domain-lock и DOM-шумом.

Влияние: кража учётных данных Google-аккаунтов владельцев каналов. Компрометации жертв не наблюдалось. Оценка риска кампании: High (перехват вторых факторов с живым оператором).

Ключевые выводы:

- Доставка через группу Google: Google рассылает пост каждому участнику со своими валидными DKIM/SPF/DMARC, поэтому почтовая аутентификация и репутация домена не помогают; ссылка — короткая share.google.
- Видимый текст ссылки (youtube.studio/dmca-policy/alerts) — незарегистрированный домен; настоящая цель — copyright-library[.]com (зарегистрирован 3 октября 2026).
- Кит — не статичная форма: это окно Browser-in-the-Browser под управлением скрипта, который занимает живой слот оператора, раз в 5 секунд опрашивает команды оператора и сообщает текущий шаг жертвы; поддерживаются пароль, Google-prompt, SMS, TOTP, код на резервную почту, номер телефона и backup-коды.
- Domain-lock кита разрешает ещё два домена, которые сейчас резолвятся (ytchannelinfo[.]com, verify1you-be-main213047298[.]com); вероятнее всего это параллельные или staging-инсталляции (не проверено).
- Факты о коде: маркер движка «collabix», билд v=20261016h (16.10.2026), русскоязычные строки интерфейса и hl=ru во вшитом URL Google. Родство с PhaaS-семейством, описанным в апреле 2026, по коду не подтверждено.

2. Хронология

Дата / время	Событие
2026-10-02 / 03	Зарегистрированы dmcaalertsinfo[.]com и copyright-library[.]com
2026-10-05 / 06	copyright-library[.]com делегирован DNS-провайдеру и направлен на 94[.]26[.]90[.]86; страница изменена 06.10
2026-10-08 / 11	Публичные сканы домена кита (разные значения отслеживающего параметра)
2026-10-13	Сообщение разослано через группу Google
2026-10-16	Метка версии скрипта кита (v=20261016h)

3. Поддельное уведомление YouTube DMCA

Доставка. Текст письма («Account Update Information») сообщает, что контент на аккаунте получателя отмечен для проверки авторских прав; видимый текст ссылки — youtube.studio/dmca-policy/alerts (домен не зарегистрирован), а настоящий href — короткая ссылка share.google.

Сообщение опубликовано в группе Google, поэтому Google доставляет его каждому участнику со своими валидными DKIM/SPF/DMARC; отображаемое имя группы — «YouTube». Результаты аутентификации и служебная пометка в заголовках указывают, что пост сделан из потребительского аккаунта Gmail (Medium). Сообщение в группу — веер по списку участников, а не адресная атака.

Цепочка редиректов. share.google отвечает 302 на endpoint google.com, тот отвечает 301 на copyright-library[.]com. Домен зарегистрирован 2026-10-03 (NiceNIC), использует ClouDNS и резолвится в 94[.]26[.]90[.]86 (DEDIK, AS207043); родственный домен dmcaalertsinfo[.]com (регистрация 2026-10-02) занимал тот же адрес с 3 по 10 октября. Страницу отдаёт nginx с приложением Express, последнее изменение 6 октября. Публичные сканы этого домена 8 и 11 октября содержат разные значения отслеживающего параметра запроса, то есть параметр обозначает канал распространения или партнёра.

Кит («Copyright Library»). Посетитель вводит ссылку на канал YouTube или @handle, видит «There is a DMCA strike on your channel ... 1/3 strikes» и кнопку «Sign in with Google». Перед открытием iframe с оверлеем входа inline-скрипт отправляет POST на /api/submit-form с JSON (ссылка на канал, имя канала, ID дела, ID видео, IP посетителя, полученный через публичный сервис определения IP, ОС, ref). Оверлей (auth-verifi/?continue_verifi_userID_182iqqUTqwjRequestYoutube, 148 КБ) содержит фальшивые атрибуты jscontroller/jsaction/jsname, скрытые элементы data-noise и комментарий разработчика «anti-screenshot disabled per request» против детекторов. config.js — шаблонный файл с «брендами»-заглушками (netflix, oracle, riot и др.) и фиктивными реквизитами компании, что говорит о собранном или продаваемомките.

3.1 Статический анализ script.js

script.js (265 737 байт) деобфусцирован статически, не исполнялся. Это не форма и не сборщик паролей, а оркестратор окна Browser-in-the-Browser (BitB): поддельное окно браузера с фальшивой адресной строкой (пути accounts.google.com, замок, окно сертификата, перетаскиваемый заголовок) в вариантах для Windows (Chrome, Firefox), macOS, iOS (Safari, Chrome) и Android. Сами шаги входа загружаются во внутренний iframe.

Сессия оператора в реальном времени. Скрипт занимает слот у бэкенда (POST /youtube/api/slot/claim; если слоты заняты, бэкенд отвечает 503, а жертва видит русскоязычное сообщение, что все слоты заняты, со счётчиками live/collecting). Каждые 5 секунд он опрашивает /youtube/api/slot/ping и выполняет команды оператора (перезапуск с финальным редиректом, принудительный возврат на страницу выбора второго фактора). Каждые 500 мс он читает путь внутреннего iframe и сообщает текущий шаг жертвы на /youtube/api/current-page, меняя текст фальшивой адресной строки. Цель финального редиректа запрашивается у /youtube/api/success-config и выбирается оператором. Запросы несут заголовки X-Session-Token и X-Visitor-Id. Каналов Telegram, webhook, WebSocket или socket.io в клиентском коде нет; такой канал мог бы быть только серверным.

Поддерживаемые факторы (по карте шагов скрипта): e-mail/идентификатор, пароль, выбор способа второго фактора, Google-prompt на устройстве, другое устройство, ввод номера телефона, SMS-код, TOTP (приложение-аутентификатор), код на резервную почту и backup-коды, а также ручной шаг «неверно, повторите» и шаг «сессия истекла». Страницы этих шагов (/youtube/<шаг>/ с

идентификатором сессии) не захвачены и требуют валидной сессии, поэтому реальные поля и endpoint отправки учётных данных не установлены; в коде не видно понижения до пароля вместо passkey (не подтверждено и не исключено). Это релей-кит с оператором в контуре, а не reverse-proxy AiTM.

Анти-анализ. script.js обфусцирован obfuscator.io с пресетом high (RC4-массив строк, self-defending, цикл debugger, отключённый вывод консоли) и содержит domain-lock, перенаправляющий на about:blank вне разрешённых доменов. Lock разрешает ещё два домена, которые сейчас резолвятся: ytchannelinfo[.]com и verify1you-be-main213047298[.]com (оба за Cloudflare); их роль не подтверждена, вероятнее всего это параллельные или staging-инсталляции. HTML прячет текст в closed Shadow DOM, использует случайные имена классов, поддельные атрибуты Google jscontroller/jsaction и скрытые элементы-шум и грузит картинки через API как blob, чтобы ломать сигнатуры по хешам и скрейперы.

Признаки семейства (факты о коде, не атрибуция): имя движка «collabix» (__collabixSkipAutoFocusOnce, collabix:introAnimationDone), метка билда v=20261016h, русскоязычные строки интерфейса, hl=ru в URL Google, вшитом в фальшивую адресную строку, и отслеживающий параметр, сохраняемый как партнёрский (worker) код. Сравнение с PhaaS-семейством из публикации Malwarebytes за апрель 2026 (тот же жанр: поддельное уведомление YouTube об авторских правах, ведущее ко входу Google): строки и схема API кода не совпадают, поэтому родство не подтверждено.

Цель: Google-аккаунт владельца канала, включая перехват вторых факторов. Оператор не определён.

Связь с прежним случаем: 13 октября это же сообщение было известно только по снимку экрана, с видимым доменом youtube.studio (не зарегистрирован с 2020 года) и неизвестной целью; тот случай был закрыт без отчёта в ожидании оригинала. Теперь оригинал получен, цель установлена. Сравнение с PhaaS-семейством, описанным Malwarebytes в апреле 2026: общий жанр (поддельное уведомление YouTube об авторских правах), партнёрский отслеживающий параметр, оверлей входа; отличия: другие имена endpoint и схема API, нет кириллических гомоглифов. Родство по коду не подтверждено.

4. Связь с другими кампаниями

Billing-письмо под Hetzner, исследованное параллельно, с этой кампанией не связано (уверенность High): инфраструктура, кит и мейлер не имеют ничего общего.

5. Индикаторы компрометации (IOC)

Все значения дефанжены. to_ids показывает, пригодно ли значение для списков блокировки. share.google, groups.google.com и youtube.studio индикаторами не являются.

Тип	Значение	Контекст / уверенность	to_ids
IP	94[.]26[.]90[.]86	Хост DMCA-кита (DEDIK, AS207043). Medium-High	true
Domain	copyright-library[.]com	Кит «DMCA-страйк» ,	true

		зарегистрирован 2026-10-03 (NiceNIC). High	
Domain	dmcaalertsinfo[.]com	Родственный DMCA-домен, зарегистрирован 2026-10-02; сейчас не резолвится. Medium	true
Domain	ytchannelinfo[.]com	Разрешён в domain-lock кита; резолвится (Cloudflare); роль не подтверждена, вероятнее всего параллельная или staging-инсталляция. Medium	true
Domain	verify1you-be-main213047298[.]com	Разрешён в domain-lock кита; резолвится (Cloudflare); роль не подтверждена, вероятнее всего параллельная или staging-инсталляция. Medium	true
String	/youtube/api/slot/claim	Бэкенд кита: занять слот оператора (503 со счётчиками live/collecting, если слоты заняты). High	false
String	/youtube/api/slot/ping	Бэкенд кита: heartbeat раз в 5 с и канал команд оператора. High	false
String	/youtube/api/current-page	Бэкенд кита: отчёт о текущем шаге жертвы раз в 500 мс. High	false
String	/youtube/api/pushmfa-context	Бэкенд кита: контекст для шага фальшивого Google-prompt. High	false
String	/youtube/api/success-config	Бэкенд кита: финальный редирект, задаваемый оператором. High	false
Header	X-Session-Token	Заголовок запросов кита к бэкенду (вместе с X-Visitor-Id). Medium	false
String	__collabixSkipAutoFocusOnce	Внутреннее имя движка «collabix» в скрипте кита (также событие collabix:introAnimationDone). High	false
String	v=20261016h	Метка билда script.js и modal.css (билд 16.10.2026). High	false
String	Все слоты сейчас заняты. Попробуйте через минуту.	Русскоязычное сообщение жертве, когда все слоты оператора заняты. High	false
String	58 Riverside Ave, Suite 200, Rockford, IL 61101	Фиктивные реквизиты компании «Copyright Library» на лендинге	false

		(строка-сигнатура). High	
String	/api/submit-form	POST-endpoint, вызываемый перед оверлеем входа. High	false
String	auth-verifi/?continue_verifi_userID_182iqqUTqwjRequestYoutube	путь iframe оверлея входа (одинаков для всех посетителей). High	false
String	window.CL.getChannelInfo; "Copyright Library"	объект скрипта и заголовок страницы. High	false
SHA256	0b2a4cd076aec476b99b9cb37c5eb7c95fe45cb7b3cfcd26c218012609118f3a	главная страница. High	false (page changes)
SHA256	a6c66736a96753a90cceadd02fbe5d607aa10b0c9cabfd75af15df3f65148238	страница iframe оверлея входа. High	false (page changes)
SHA256	e6fc7ee9483f9ecc388e6e0eededf062f7a4333fa92c4b7f8b53c855f6e87d62	script.js (obfuscator.io), 265 737 байт. High	false (page changes)
SHA256	f59fc322ad252f01c9744811e871e40874dd90efdffee60cb88fd5d857db5450	assets/js/config.js. High	false (page changes)

6. Сопоставление с MITRE ATT&CK

Тактика	Техника	ID	Основание / статус
Reconnaissance	Gather Victim Host Information	T1592	Кит собирает IP посетителя (через публичный сервис определения IP) и ОС. Подтверждено (код)
Resource Development	Acquire Infrastructure: Domains	T1583.001	copyright-library[.]com, dmcaalertsinfo[.]com. Подтверждено
Resource Development	Acquire Infrastructure: VPS	T1583.003	Сервер DEDIK. Подтверждено
Resource Development	Acquire Infrastructure: Web Services	T1583.006	Google Groups, share.google. Подтверждено
Resource Development	Establish Accounts: Email Accounts	T1585.002	Потребительский почтовый аккаунт для публикации в группе. Возможно
Resource Development	Stage Capabilities: Link Target	T1608.005	copyright-library[.]com. Подтверждено
Initial Access	Phishing: Spearphishing Link	T1566.0	Ссылка в сообщении группы.

		02	Подтверждено
Initial Access	Valid Accounts: Cloud Accounts	T1078.004	Цель: Google-аккаунты владельцев каналов. Гипотеза
Execution	User Execution: Malicious Link	T1204.001	Требуется клик. Подтверждено (замысел)
Defense Evasion	Impersonation	T1656	Уведомление YouTube / DMCA. Подтверждено
Defense Evasion	Masquerading: Match Legitimate Resource Name or Location	T1036.005	Видимый текст ссылки youtube.studio. Подтверждено
Defense Evasion	Obfuscated Files or Information	T1027	obfuscator.io в script.js, DOM-шум. Подтверждено
Credential Access	Input Capture: Web Portal Capture	T1056.003	Страницы ввода пароля и второго фактора внутри фальшивого окна браузера; страницы ввода не захвачены. Вероятно (код)
Credential Access	Adversary-in-the-Middle	T1557	Релей сессии входа оператором в реальном времени (слоты, heartbeat-команды). Подтверждено (код)
Credential Access	Multi-Factor Authentication Interception	T1111	Шаги SMS, TOTP, резервной почты, телефона и backup-кодов. Подтверждено (код)
Credential Access	Multi-Factor Authentication Request Generation	T1621	Шаг фальшивого Google-prompt («нажмите Да») с контекстом от оператора. Возможно
Defense Evasion	Virtualization/Sandbox Evasion: System Checks	T1497.001	Цикл debugger, domain-lock (about:blank вне разрешённых доменов), DOM-шум, closed Shadow DOM. Подтверждено (код)

7. Детектирование

7.1 Почта

- Ссылки share.google/* в письмах от googlegroups.com с брендовым текстом (YouTube, DMCA, copyright).
- Сообщение из группы Google, у которой отображаемое имя имитирует вендора (YouTube, Google), а текст просит перейти по ссылке для проверки политик или авторских прав.

7.2 Сеть и контент (строки для YARA / прокси / краулеров)

- Строки кита: continue_verifi_userID_, /api/submit-form, window.CL.getChannelInfo, «Copyright Library — config.js», data-noise-json.

- Пути бэкенда кита: /youtube/api/slot/claim, /youtube/api/slot/ping, /youtube/api/current-page, /youtube/api/pushmfa-context, /youtube/api/success-config; заголовок запросов X-Session-Token (вместе с X-Visitor-Id).
- Строки движка и билда: __collabixSkipAutoFocusOnce, collabix:introAnimationDone, v=20261016h; русскоязычный текст «Все слоты сейчас заняты. Попробуйте через минуту.»; фиктивные реквизиты «58 Riverside Ave, Suite 200, Rockford, IL 61101».
- Поведение: POST на .../slot/claim с ответом HTTP 503 и JSON со счётчиками live/collecting (все слоты оператора заняты); страница, периодически отправляющая POST на .../slot/ping и .../current-page; страница, перенаправляющая на about:blank вне зашитого списка доменов.
- Новые сертификаты и новые имена на 94[.]26[.]90[.]86 следует считать новыми волнами; запрос на /api/submit-form с JSON из данных канала и посетителя предшествует оверлею входа.

8. Рекомендации

Немедленные действия

- Если кто-либо когда-либо вводил пароль или код на такой странице (окно, похожее на вход Google, внутри веб-страницы), немедленно сменить пароль Google, завершить все сессии, проверить способы восстановления и пройти Google Security Checkup. Предпочитать passkey или аппаратные ключи: коды и подтверждения оператор может ретранслировать в реальном времени.
- Настоящее окно входа — отдельное окно браузера или системный диалог, а не часть страницы: его адресную строку нельзя перетащить внутри содержимого страницы.
- Блокировать или оповещать по индикаторам с to_ids=true.
- Добавить правила раздела 7 на почтовый шлюз и веб-прокси.
- Страйки YouTube проверять только в YouTube Studio, открытой напрямую; включить passkey или двухэтапную аутентификацию и пройти Google Security Checkup; выйти из групп Google, в которые вы не вступали осознанно, и фильтровать их письма.
- По умолчанию считать сообщения из групп Google недоверенными: Google подписывает их, но содержимое пишет автор поста. Разрешать доставку только из известных групп.

Долгосрочные меры

- Почтовая защита не должна считать подписи Google или домен google.com в цепочке ссылок сигналом доверия: перед оценкой нужно раскрывать цель короткой ссылки.
- Взять 94[.]26[.]90[.]86 на мониторинг пассивного DNS и сертификатов.
- Со стороны Google: злоупотребление короткими ссылками share.google и постами групп для подделки бренда — вопрос оператора сервиса.

9. Уверенность и ограничения

Вывод	Уверенность
Письмо — credential-фишинг	High
Цель кита — copyright-library[.]com; кит — BitB-релей с живым оператором (по статическому анализу скрипта)	High
Поддерживаемые факторы: пароль, Google-prompt, SMS, TOTP, резервная почта, телефон, backup-коды (по карте шагов)	High / Medium
ytchannelinfo[.]com и verify1you-be-main213047298[.]com разрешены domain-lock и резолвятся; что на них стоит тот же кит, — предположение	Medium
Кит относится к PhaaS-семейству апреля 2026 (по коду не подтверждено)	Not confirmed
Не связано с параллельным письмом под Hetzner	High

Личность оператора	Не установлено

Пробелы: страницы шагов входа и endpoint отправки учётных данных не захвачены (нужна валидная сессия), понижение до пароля вместо passkey не подтверждено и не исключено, серверный канал оператора не виден; данные прозрачности сертификатов по dmcaalertsinfo[.]com недоступны; саму группу изучить не удалось. Все страницы и индикаторы отражают состояние на 21 октября 2026.

10. Источники

- Malwarebytes, 15 апреля 2026, «Fake YouTube copyright notices can steal your Google login».
- Mimecast, «Google Redirect Abuse»; TechRepublic, «Trusted Google Alerts Hijacked» (злоупотребление редиректорами Google в фишинге).
- Пассивный DNS, прозрачность сертификатов, RDAP/WHOIS, публичные архивы сканов URL и публичные базы абьюз-репортов (состояние на 21 октября 2026).

Дата отчёта: 2026-10-21

TLP:CLEAR — Этот документ может распространяться без ограничений.